

Laporan_Bug_Hunter_90

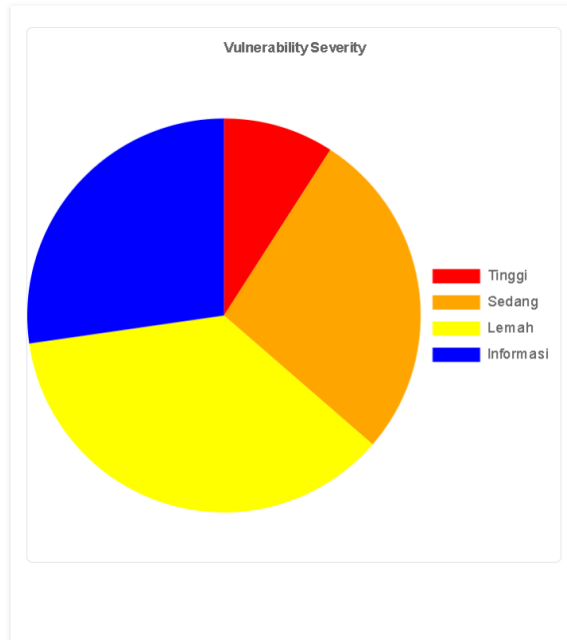
Generated on Min, 30 Agu 2026 17:21:57

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Most Severe Alert

High

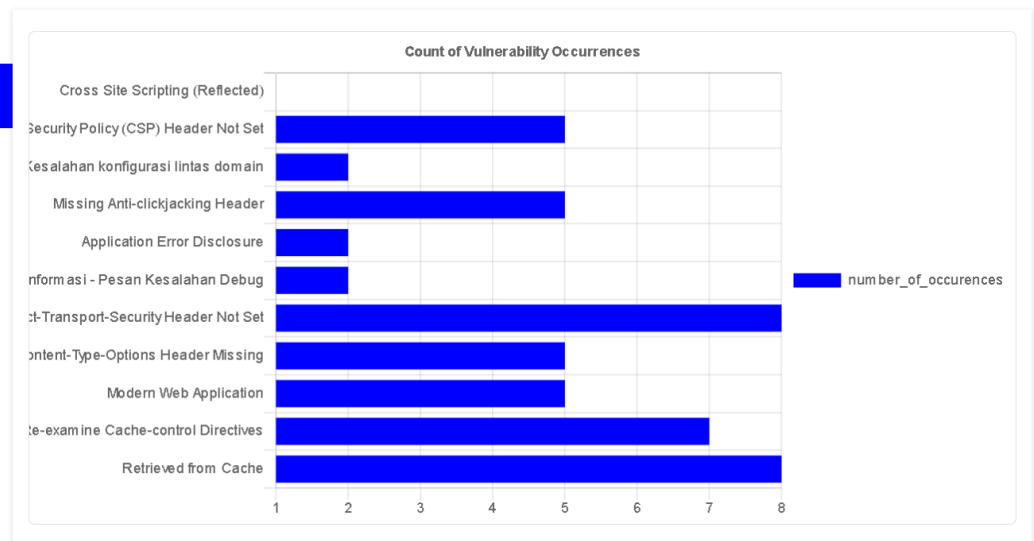


Report Description

- Laporan ini ditulis dan disusun oleh :
- Habib Muzakki (Habib)
- Alumni Kelas 12 Agama (jurusan Agama)
- Alumni MAN 2 KOTA SERANG
- Mahasiswa D4 Vokasi Teknik Informatika (Universitas Harkat Negeri Tegal)
- Wota JKT48 (Fans JKT48)
- Calon Bug Hunter (Bug Bounty)

Most Common Bug

Strict-Transport-Security Header Not Set (8)



Insights

Level	Alasan	Site	Deskripsi	Statistic
Lemah	Peringatan		ZAP warnings logged - see the zap.log file for details	9
Info	Informasi	https://content-autofill.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://content-autofill.googleapis.com	Percentage of endpoints with content type text/plain	100 %
Info	Informasi	https://content-autofill.googleapis.com	Percentage of endpoints with method GET	100 %
Info	Informasi	https://content-autofill.googleapis.com	Count of total endpoints	2
Info	Informasi	https://content-autofill.googleapis.com	Percentage of slow responses	100 %

Info	Informasi	https://fonts.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://fonts.googleapis.com	Percentage of endpoints with content type text/css	100 %
Info	Informasi	https://fonts.googleapis.com	Percentage of endpoints with method GET	100 %
Info	Informasi	https://fonts.googleapis.com	Count of total endpoints	1
Info	Informasi	https://fonts.googleapis.com	Percentage of slow responses	100 %
Info	Informasi	https://fonts.gstatic.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://fonts.gstatic.com	Percentage of endpoints with content type font/woff2	100 %
Info	Informasi	https://fonts.gstatic.com	Percentage of endpoints with method GET	100 %
Info	Informasi	https://fonts.gstatic.com	Count of total endpoints	1
Info	Informasi	https://fonts.gstatic.com	Percentage of slow responses	33 %
Info	Informasi	https://xss-game.appspot.com	Percentage of responses with status code 2xx	70 %
Info	Informasi	https://xss-game.appspot.com	Percentage of responses with status code 4xx	19 %
Info	Informasi	https://xss-game.appspot.com	Percentage of responses with status code 5xx	9 %
Info	Informasi	https://xss-game.appspot.com	Percentage of endpoints with content type image/png	14 %
Info	Informasi	https://xss-game.appspot.com	Percentage of endpoints with content type text/css	18 %
Info	Informasi	https://xss-game.appspot.com	Percentage of endpoints with content type text/html	33 %
Info	Informasi	https://xss-game.appspot.com	Percentage of endpoints with content type text/javascript	25 %
Info	Informasi	https://xss-game.appspot.com	Percentage of endpoints with content type text/plain	7 %
Info	Informasi	https://xss-game.appspot.com	Percentage of endpoints with method GET	100 %
Info	Informasi	https://xss-game.appspot.com	Count of total endpoints	27
Info	Informasi	https://xss-game.appspot.com	Percentage of slow responses	91 %

Vulnerability Impact

#	Name	Impact
Cross Site Scripting (Reflected) [1] [2]	Cross-site Scripting (XSS) adalah sebuah teknik serangan yang melibatkan penyerang yang bergema disediakan misalnya kode ke browser pengguna. Browser misalnya dapat menjadi standar klient browser web, atau sebuah objek browser tertanam dalam produk perangkat lunak seperti browser hanya WinAmp, aplikasi RSS reader, atau klien email. Kode itu sendiri biasanya ditulis dalam HTML/JavaScript, tetapi juga dapat memperpanjang untuk VBScript, ActiveX, Java, Flash, atau browser lain	

	yang didukung teknologi.	
Content Security Policy (CSP) Header Not Set [1] [2] [3] [4] [5] [6] [7]	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.	
Kesalahan konfigurasi lintas domain [1]	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.	
Missing Anti-clickjacking Header [1]	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.	
Application Error Disclosure	This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page.	
Pengungkapan Informasi -	Respon tersebut tampaknya mengandung	

Pesan Kesalahan Debug	pesan kesalahan umum yang dikembalikan oleh platform seperti ASP.NET, dan Web-server seperti IIS dan Apache. Anda dapat mengkonfigurasi daftar pesan debug umum.	
Strict-Transport-Security Header Not Set [1] [2] [3] [4] [5]	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.	
X-Content-Type-Options Header Missing [1] [2]	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.	
Modern Web Application	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.	
Re-examine Cache-control Directives [1] [2] [3]	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the	

	resources should be reviewed to ensure that no sensitive content will be cached.	
Retrieved from Cache [1] [2] [3]	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.	